

Mise en conformité

NIS2 : cas HydroRégie

Introduction

Ce cas pratique s'inscrit dans la continuité du projet RGPD conduit précédemment.

La directive (UE) 2022/2555, dite NIS2, élargit très fortement le nombre d'entités soumises à des obligations de cybersécurité et responsabilise directement les organes de direction.

Vous êtes dans la situation d'une équipe projet mandatée par HydroRégie, une régie des eaux qualifiée d'entité essentielle, pour conduire sa mise en conformité : qualification réglementaire, analyse des écarts, gouvernance, architecture technique et gestion de crise.

HydroRégie dessert 450 000 habitants. Son système d'information de gestion (IT) et son système industriel (OT) ne sont aujourd'hui pas cloisonnés, ce qui expose l'ensemble de l'infrastructure en cas d'incident. Un courrier de

l'autorité nationale vient de confirmer son statut d'entité essentielle au titre de NIS2 : à vous d'auditer, concevoir et défendre sa mise en conformité.

Compétences visées

Qualifier une entité au regard de la directive NIS2 (secteur, taille, statut essentiel ou important)

Conduire une analyse d'écart et bâtir une feuille de route de mise en conformité

Concevoir une architecture réseau segmentée entre le système d'information de gestion (IT) et le système industriel (OT)

Piloter une gestion de crise cyber et respecter les obligations de notification réglementaire

Déroulement du cas pratique

Le cas se déroule sur 2 jours, organisés en 4 blocs .

Jour 1 – Gouvernance et conformité

Bloc 1 – Qualification de l’entité au regard de NIS2 : secteur d’activité, taille, statut essentiel ou important, obligations associées (gouvernance, mesures, notification). Livrable : note de qualification réglementaire.

Bloc 2 – Analyse d’écart et feuille de route de mise en conformité : couverture des mesures de l’article 21, priorisation des écarts, plan d’actions daté et responsabilisé. Livrable : analyse d’écart et feuille de route.

Jour 2 – Technique et gestion de crise

Bloc 3 – Architecture réseau segmentée IT/OT : zones, DMZ, niveaux de criticité, choix techniques justifiés (pare-feu, VLAN, VPN), prise en compte de la continuité du service d’eau potable. Livrable : schéma d’architecture argumenté.

Bloc 4 – Gestion de crise cyber et notification réglementaire : chronologie détection/qualification/escalade/remédiation, respect des délais de notification (alerte précoce 24h, notification 72h, rapport final 1 mois). Livrable : chronologie de gestion de crise et notifications réglementaires rédigées.

Rendu

Le rendu est à déposer sur GitHub, dans un dossier structuré, contenant l'ensemble des livrables produits pour les 4 blocs notés dans la grille d'évaluation : (1) qualification NIS2, (2) analyse d'écart et feuille de route de mise en conformité, (3) schéma d'architecture réseau segmentée IT/OT, (4) chronologie de gestion de crise et notifications réglementaires rédigées.

<https://github.com/prenom-nom/NIS2>

Base de connaissances

- Le texte de la directive [\(UE\) 2022/2555 \(NIS2\)](#)
- Le site de l'ANSSI dédié à la directive [NIS 2](#)
- Les ressources [NIS2 de l'ENISA](#)
- La plateforme d'enregistrement [MonEspaceNIS2](#)